



Peer Reviews (PR)

PR Overview

Required PA Information

Intent

Identifies and addresses process performance and work product issues through reviews by the producer's peers or Subject Matter Experts (SMEs).

Value

Reduces cost and rework by uncovering issues or defects early.

Additional Required PA Information

This section left blank for future content.

Explanatory PA Information

Practice Summary

Level 1

PR 1.1 Perform reviews of work products and record issues.

Level 2

PR 2.1 Develop and keep updated procedures and supporting materials used to prepare for and perform peer reviews.

PR 2.2 Select work products to be peer reviewed.

PR 2.3 Prepare and perform peer reviews on selected work products using established procedures.

PR 2.4 Resolve issues identified in peer reviews.

Level 3

PR 3.1 Analyze results and data from peer reviews.

Additional PA Explanatory Information

Performing peer reviews helps to find issues and remove defects from work products early. A peer review is an important and effective verification, validation, and assurance activity. Peer reviews may be implemented via inspections, structured walkthroughs, audits, or other review methods. Peers or relevant SMEs methodically and objectively examine work products to identify defects for removal.

Teams performing peer reviews can benefit from:

- Defining selection criteria to focus on the most important areas
- Selecting what to peer review

- Performing peer reviews thoroughly with multiple viewpoints
- Analyzing data to identify quality trends and improvements

Issues found during peer reviews may include:

- Defects related to work products
- Performance or functional issues
- Process-related issues
- Cost, risk, and schedule issues

Performing a peer review includes:

- Preparing for review
- Selecting methods or techniques
- Reviewing the work products
- Recording the data

Perform peer reviews incrementally as work products are developed. Peer reviews are structured and are not management or status reviews.

Peer reviews can be applied to any work product regardless of who produced it. The focus of the peer review should be on the work product, not on the author. When defects are identified during a peer review, communicate them to the author for correction.

The most effective peer reviews ensure that participants are objective and candid about their evaluations. Protect peer review data collected to prevent inappropriate use, such as:

- Disciplining or rewarding people
- Publicly criticizing or praising performance
- Violating data security and privacy laws

Related Practice Areas

Verification and Validation (VV)

Context Specific

Agile Development

Context Tag:	Agile Development
Context:	Integrate agile techniques and ceremonies with other processes.

Examples of where peer reviews can be performed in an agile project typically include:

- Backlog grooming
- Reviewing completed stories during each iteration with product owner
- Use of paired, team, or mob programming during each iteration
- Pull requests
- Design, test plans, test cases, and code work products reviews

Results from peer reviews are often captured in automated tools.

DevSecOps

Context Tag:	DevSecOps
Context:	DevSecOps is a mindset, a culture, and set of practices that fosters close cooperation between development, operations, and security to plan, develop, test, deploy, release, and keep updated a secure solution.

DevSecOps teams typically use a mix of automated and manual code reviews to maintain software quality. Often static code analysis tools are used to detect and correct common coding mistakes and vulnerabilities based on criterion setting in the tool. The team can adjust these settings over time as they learn more about their code and understand trends or false positives. Another critical review required in DevSecOps is the configurations of the tools itself. The choices on customization can easily leak defects and vulnerabilities. Hence Peer Reviews on the pipeline setup configurations, automation scripts, etc. are important for DevSecOps. Several popular tools are available to perform this type of analysis. DevSecOps teams also incorporate static application security testing to identify security vulnerabilities and hotspots into their Continuous Integration / Continuous Delivery (CI/CD) pipeline. Security vulnerabilities typically involve an immediate threat or risk to operations and hence require continuous focus on security hotspots where presence of security sensitive code may require a manual peer review to take immediate action. These manual peer reviews are typically accomplished as part of a design or code review request and use a set of coding standards and secure coding practices to evaluate the code for defects or vulnerabilities.

Level 1

PR 1.1

Required Practice Information

Practice Statement

Perform reviews of work products and record issues.

Value

Improves work product quality and reduces cost and rework by uncovering issues early.

Additional Required Information

This section left blank for future content.

Explanatory Practice Information

Additional Explanatory Information

This section left blank for future content.

Example Activities

Example Activities	Further Explanation
Review work products to identify issues.	Consider the processes that contribute to the creation and enhancements of the work products.
Record results.	

Example Work Products

Example Work Products	Further Explanation
List of issues from work product reviews	Identifies the: • Work product reviewed • Issues

Level 2

PR 2.1

Required Practice Information

Practice Statement

Develop and keep updated procedures and supporting materials used to prepare for and perform peer reviews.

Value

Maximizes efficiency and effectiveness of finding issues in peer reviews.

Additional Required Information

This section left blank for future content.

Explanatory Practice Information

Additional Explanatory Information

This section left blank for future content.

Example Activities

Example Activities	Further Explanation
Record and keep updated peer review procedures.	
Record and keep updated related supporting materials.	

Example Work Products

Example Work Products	Further Explanation
Procedures for preparing for and performing peer reviews	Procedures may include: • Criteria for selecting and reviewing work products • Selecting work products • Deciding peer review type • Work product evaluation criteria • Selecting participants and assigning roles • Preparing and distributing review material • Peer review steps
Supporting materials	May include: • Work product standards and templates • Work product creation processes • Work product functionality and quality attributes

Example Work Products	Further Explanation
	• Common issues or defect types The above items may be included as part of a checklist.

Context Specific

DevSecOps

Context Tag:	DevSecOps
Context:	DevSecOps is a mindset, a culture, and set of practices that fosters close cooperation between development, operations, and security to plan, develop, test, deploy, release, and keep updated a secure solution.

DevSecOps teams establish their automated code review criteria through the tool setting they are using for their static code analysis. These settings are often part of the procedure/process embedded in the Continuous Integration / Continuous Delivery (CI/CD) systems and pipeline; those automated procedures should include defining a periodic frequency for re-evaluating the review criteria in the tool, which code and items are subject to manual code review, and the types of tests the tools perform. Periodic reviews and verifications of the criteria and procedures in the tool are performed on a periodic and as needed basis. Additional manual code reviews serve as a manual gate-check for code changes before merging them to the trunk branch. This helps ensure quality and security by preventing developers from working in a vacuum and makes the team aware of project status and progress. Once the code review is completed, the issues addressed, and the code is merged into the trunk branch, a build is initiated as part of the CI/CD pipeline where additional unit tests are run, and issues resolved. DevSecOps teams leverage lean development practices with the goal of making small commits and frequent merges. This typically results in multiple daily code pull requests. Incorporating peer reviews with pull requests addresses issue resolution in a more timely and effective manner in line with a shift left approach.

PR 2.2

Required Practice Information

Practice Statement

Select work products to be peer reviewed.

Value

Manages costs by targeting critical work products for peer review.

Additional Required Information

This section left blank for future content.

Explanatory Practice Information

Additional Explanatory Information

This section left blank for future content.

Example Activities

Example Activities	Further Explanation
Evaluate the criticality of the work product.	It may not be possible to review every work product or process. For large or complex work products, it may not be possible to review the entire work product. The evaluation should consider the highest priority work products or elements. Example criteria include: the most critical section, the most used by the user, the costliest if defective, the most error-prone, the least well understood section, or the most frequently changed section.
Determine and record the review type to use.	Different work products or processes may be more effectively reviewed using different techniques or methods. Types of peer reviews may include: • Inspections • Structured walkthroughs • Perspective-based reviews, which involve assigning reviewer perspectives such as: ○ Standards ○ Domains ○ Types of issues • Objective evaluations

Example Work Products

Example Work Products	Further Explanation
Work product or process selection criteria	
List of selected work products or processes	Include the: • Work product • Process descriptions and steps • Review type

Context Specific

DevSecOps

Context Tag:	DevSecOps
Context:	DevSecOps is a mindset, a culture, and set of practices that fosters close cooperation between development, operations, and security to plan, develop, test, deploy, release, and keep updated a secure solution.

DevSecOps teams perform design reviews prior to development and then code review on all their code as part of the code pull request process and Continuous Integration / Continuous Delivery (CI/CD) pipeline as they are sequenced in the planned agile epics and Sprints. The CI/CD pipeline and tool setup are in the plan and should include clear criteria for which code is subject to automated reviews and tests, which is covered by a manual review, and how peer review comments and actions are captured and resolved.

PR 2.3

Required Practice Information

Practice Statement

Prepare and perform peer reviews on selected work products using established procedures.

Value

Reduces cost by thorough and consistent review to detect work product issues.

Additional Required Information

This section left blank for future content.

Explanatory Practice Information

Additional Explanatory Information

This section left blank for future content.

Example Activities

Example Activities	Further Explanation
Develop schedule.	This should be integrated with the work schedule.
Follow procedures.	
Record results from the peer reviews and the data from the process.	May include: • List of issues found in the peer reviews • Data related to process aspects, e.g., prep time, number of work products or processes, time spent in peer reviews

Example Activities	Further Explanation
Communicate results to affected stakeholders.	Results include the peer review process data and the issues.

Example Work Products

Example Work Products	Further Explanation
List of work products	
Schedule	May include: • Planned date, time, and duration • Reviewers
Peer review results	May include: • Completed supporting materials • Issues • Action items • Data which may include: ○ Time spent in preparing for and performing the review ○ Role and number of reviewers ○ Number and type of issues, defects, or actions ○ The size of the work product examined ○ Type of peer review ○ Resolution of issues or defects ○ Estimated rework time ○ Defect origin ○ Number of issues or defects expected ○ Causes of defects ○ Affected stakeholders

Related Practice Areas

Managing Performance and Measurement (MPM)

Context Specific

DevSecOps

Context Tag:	DevSecOps
Context:	DevSecOps is a mindset, a culture, and set of practices that fosters close cooperation between development, operations, and security to plan, develop, test, deploy, release, and keep updated a secure solution.

Through the tools and embedded criteria in them, DevSecOps teams determine which code or work products are manually peer reviewed and when and how these reviews are conducted. Collectively between the Continuous Integration / Continuous Delivery (CI/CD) pipeline, tools, criteria, and settings, the team uses these to:

- Validate requirements
- Verify that coding standards and code review criteria are followed
- Describe which types of tests the tools perform

Manual code reviews are typically performed as part of a code pull or code review request and use a set of coding standards and secure coding practices to evaluate the code for defects or vulnerabilities. Paired programming and other techniques can also be used to address code quality. Action items for addressing peer review issues are then parsed into the automated tools or made directly in the code.

PR 2.4

Required Practice Information

Practice Statement

Resolve issues identified in peer reviews.

Value

Reduces rework, costs, and increases quality.

Additional Required Information

This section left blank for future content.

Explanatory Practice Information

Additional Explanatory Information

This section left blank for future content.

Example Activities

Example Activities	Further Explanation
Resolve issues.	
Record resolutions and results and communicate to affected stakeholders.	Include expectations for when actions will be closed by affected stakeholders.

Example Work Products

Example Work Products	Further Explanation
Resolution of issues	
Results	May include data resulting from the review.

Level 3

PR 3.1

Required Practice Information

Practice Statement

Analyze results and data from peer reviews.

Value

Increases the efficiency and effectiveness of the process for performing peer reviews.

Additional Required Information

This section left blank for future content.

Explanatory Practice Information

Additional Explanatory Information

One of the primary objectives of peer reviews is to identify and remove defects early in the project. Analysis of results can help identify trends in defect injection and sources and types of defects.

In addition, it is important to analyze data about the preparation and conduct of peer reviews in order to determine the efficiency and effectiveness of the peer review process.

Example Activities

Example Activities	Further Explanation
Analyze peer review process data and the results from the peer review.	
Record and communicate analysis results.	This typically includes: • When defect was injected • Preparation time or rate versus expected time or rate • Number of issues versus number expected • Types of issues detected • Causes of issues • Issue resolution impact • Stakeholders associated with issues

Example Work Products

Example Work Products	Further Explanation
Analysis results	Analysis of peer review data can aid in avoiding, minimizing, or preventing future issues or defects. Types of analysis may include: • Causal analysis • Trend analysis • Delivery and operational analysis • Common issue resolution analysis • Peer review effectiveness and efficiency

Related Practice Areas

Causal Analysis and Resolution (CAR)

Managing Performance and Measurement (MPM)

Context Specific

DevSecOps

Context Tag:	DevSecOps
Context:	DevSecOps is a mindset, a culture, and set of practices that fosters close cooperation between development, operations, and security to plan, develop, test, deploy, release, and keep updated a secure solution.

DevSecOps teams periodically perform reviews of their analysis tool settings and criteria based on analysis results to minimize false positives, improve code quality, and adjust to changes in the application environment or emerging threats and vulnerabilities. Static code analyzers and dashboards can also be used for analysis. Analysis results from these techniques are typically covered during Retrospectives to enable the team to avoid or prevent recurrence.